Monthly Intelligence Dispatch

November 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB found that ignoring two-factor authentication resulted in the interception of Telegram correspondence.
- The Higaisa hacker group, sent out phishing emails related to Korean New Year holidays.
- In September 2019, a bank in the Asia-Pacific region fell victim to a cyberattack and its systems were encrypted with malware.
- The North Korean threat group Lazarus created another crypto trading program, which installs a backdoor on victims' Mac computers.
- Traces of a Silence attack on African banks have been discovered.
- A new database containing the data of over 400,000 bank cards belonging to Turkish banks' customers was put up for sale on Joker's Stash, an underground forum.
- An updated version of the Anubis Trojan allows attackers to gain full control over infected devices by automatically disabling the Google Protect service.

Telegram

In late 2019, several Russian entrepreneurs who had faced the problem of unauthorized access to their Telegram chats reached out to Group-IB's Investigation Department. The incidents occurred on iOS and Android devices regardless of what mobile operator the victim used. The attack started when users received a message from Telegram's service channel (the messenger's official channel with a blue verified badge) with a login code that the user did not request. The users then received an SMS with an activation code, which was almost immediately followed by a "new device login" notification on the same Telegram channel. In all the cases Group-IB is aware of, the attackers logged in to victims' accounts via the mobile Internet (they likely used one-time SIM cards), and in most cases the attackers' IP addresses were located in the city of Samara, Russia. Group-IB experts emphasize that Telegram has built-in security mechanisms enabling effective protection against attackers, but not everyone uses these mechanisms. Apart from required SMS messages, one more authentication factor—an additional password—should be enabled in Telegram. You then need to check other applications and services that use SMS for first- or second-factor authentication; one-time password delivery; or password recovery for email accounts, social media, and mobile banking applications and services. Group-IB warns that such attacks can only be successful if the Password or Two-step Verification options are turned off in Telegram's settings on a smartphone. To enable protection on iOS and Android devices, go to Telegram's Settings > Privacy and Security > Two-Step Verification > Set Additional Password. More detailed information about how to enable this option is available on the messenger's official website https://telegram.org/blog/sessions-and-2-step-verification.

Higaisa

Higaisa, a hacking group, sent out phishing emails related to the New Year holidays in Korea. Most Higaisa's attacks start with phishing emails. On February 19, 2019, one such mail-out took place. It was sent out from the address china*@162.com and targeted individuals from North Korea. The email contained congratulations on the Korean New Year holidays and had an archive attachment, "정월 대보름날 즐겁게 보내세요.zip," with an executable file within. The payload and the lure are stored in a PE resource. The downloaded file "avp.exe" is a remote access Trojan based on the open-source Gh0st RAT. The second downloaded file is "avpif.exe"; its main purpose is to collect information about the victim (system information, list of processes, list of shared resources, and file lists) and send it in encrypted form to the attacker's C&C server. Higaise has been carrying out attacks since 2016 using phishing emails with various types of attachments (executable files or malicious Word documents).

Hentaic0de

In September 2019, a bank in the Asia-Pacific region was attacked by threat actors and its systems were encrypted by malware. In their incident response operation, specialists found that the following programs had been used: Cosmosis trojan, yLoader loader, and HybirdRansom encryptor package. The specialists also discovered the traces of four other programs that were not recovered, as well as several PowerShell scripts. The scripts belong to the Hentaic0de hacktivist group, while the loader belongs to the IronTiger APT. According to Group-IB, ransomware accounted for more than a half (54%) of all mail-outs with malware in the first half of 2019. The most popular tool was Troldesh. To bypass antivirus systems, hackers send out malicious links during non-working hours with delayed activation. Over 80% of all malicious files were delivered in .zip and .rar archives as a cover-up.

SmarterASP.NET	In November 2019, SmarterASP.NET, a major ASP.NET hosting provider with over 440,000 customers, fell victim to a ransomware attack, which resulted in all data on customer servers being encrypted. According to Group-IB, recent years have seen attacks on various levels of communication infrastructures and by 2019 there had been successful Internet routing and BGP hijacking attacks; attacks on domain name registrars, administrators of root name servers and top-level domains, local systems of filtering and blocking traffic; and DNS hijacking attacks.
APT-C-34	Analysts at Qihoo 360 Netlab released a report describing a large-scale hacking operation targeted at Kazakhstan. According to the researchers, the Golden Falcon hacking group (also known as APT-C-34) was behind the numerous attacks. The victims of these incidents were not only private individuals, but also various companies and organizations: government agencies, private companies, and the education sector, as well as foreign diplomats, researchers, journalists, religious figures, and government dissidents.
APT33	The Iranian group APT33 created their own VPN network, according to Trend Micro, a cybersecurity firm. The group has been active since at least 2013 and is behind the notorious Shamoon malware. In 2019, APT33's victims included a private American company that offers services related to national security, victims connected to a university and a college in the US, and several victims in the Middle East and Asia.

Silence

Traces of a Silence attack on African banks have been discovered. On November 18, 2019, two files, “xfs.dll” and “dns.dll” were uploaded to VirusTotal. “xfs.dll” has been classified as Silence’s main tool, whose source code is based on two projets: dnscat2 and xfs-disp.exe. Earlier, Silence used similar ATM malware in their February 2019 attack on IT Bank. It is likely that the back end had an EDA (Empire DNS agent) panel deployed and all communication between the back end and the compromised infrastructure will be carried out through DNS requests.

Lazarus

The Lazarus threat group, which is linked to North Korea, created another crypto trading program that installs a backdoor on their victims’ Mac computers. The campaign closely resembles a previous operation that involved crypto trading malware called AppleJeus as well as JMT Trader. The new program is called Union Crypto Trader. The hackers developed a website that they use to promote the program. The observed sample is a standard first-stage implant, which transfers information to a remote server to download a fully functional second-stage implant. The first-stage implant has a unique aspect: the ability to directly execute the received payload from memory. On October 23, the North Korean group ran another phishing campaign sending out an MS Word document called “JD-HAL-Manager.doc” as an attachment. The file contains a malicious macro with a Base64-encoded loader, which Group-IB specialists named CuriousLoader. The specialists analyzed the loader and found its earlier versions. It turned out that one of its first appearances was recorded as early as April 2019. At the time, the loader’s compilation date was 2018-12-27 14:49:49.

Major events: attacks on banks and their customers

Joker's Stash-2

Group-IB's monitoring of card shops on October 28, 2019, revealed new databases called TURKEY-MIX on Joker's Stash, an underground marketplace for selling compromised bank cards. The database contained about 60,000 cards of Turkish banks' customers. Later, on November 27, another two parts of this database were published on Joker's Stash. They contained the data of more than 400,000 cards, which is the largest amount of textual card data put up for sale as a single database ever. Over 99% of the cards in the database belong to Turkish banks. The list is unusual and record-breaking for this region.

Cobalt

The Cobalt hacking group is carrying out new mail-outs. On November 21, 2019, a document called "Запрос по акционерам-1.docx" [Request for shareholders] and created under the name of the "Russian Ministry for the Development of the Far East and the Arctic" was uploaded to ANY.RUN, a sandbox service. Inside the document is an embedded object, clicking on which unpacks the Coblnt loader. The next day, on November 22, 2019, an email was sent out under the name of Isaiah Hardin emelyan43391osipovichev194@gmail[.]com with a PDF document "SWIFT MT101.pdf" as an attachment. The PDF contains a link, hXXps://vk.cc/a3betJ, for downloading a malicious document, "SWIFT MT101.doc," which also results in the unpacking of the Coblnt loader.

Upbit

The South Korean cryptocurrency exchange Upbit has been hacked, with hackers stealing $48.5 million worth of cryptocurrency. On November 27, Upbit suspended all deposit and withdrawal services and all other funds were transferred to a cold wallet. The official statement said the resource would resume its work in two weeks. The exchange said it would compensate the victims for all the losses they suffered, but it is unclear yet how this will be done.

Major events: vulnerabilities

CVE-2019-13720	In late October, two new vulnerabilities were described, CVE-2019-13720 and CVE-2019-13721, together with a security patch 78.0.3904.87. The former vulnerability has to do with an audio component in Google Chrome, the latter—the PDFium library. Both vulnerabilities can allow for arbitrary code execution on the target machine when an attacker tricks a user into visiting a malicious website to bypass Chrome's built-in sandbox protections. A Kaspersky Intelligence report mentioned that there were certain weak code similarities with Lazarus attacks. The profile of the targeted website, however, is more in line with DarkHotel attacks that have recently involved similar false flags pointing to other hacking groups. Group-IB's analysis of underground sources did not reveal any malicious activity related to these vulnerabilities. In particular, no exploits for these vulnerabilities were found.
CVE-2019-1429	On November 12, 2019, Microsoft released a patch for CVE-2019-1429, a zero-day Internet Explorer vulnerability. When exploited, it can allow an attacker to remotely execute arbitrary code on the victim's machine in the context of the current user. Microsoft says the vulnerability has already been exploited in the wild.

Anubis	An updated version of Anubis, an Android Trojan, was put up for sale on underground forums. The malware is distributed via Google Play services disguised as legitimate software. The updated Anubis has all the features of the old version, including web fakes, USSD requests, interception and sending of SMS messages, remote access, and so on. Anubis's updated version allows an attacker to gain complete control over the infected device by automatically disabling the Google Protect service.
Brute force	In October 2019, malware for brute forcing the admin panels of various e-commerce platforms (CMSs) was put up for sale on an underground forum. Later, similar postings appeared on other forums. In addition, this tool can be used to brute force some network services (SSH, FTP). The malware runs on various operating systems (Windows, Linux, OS for routers).
Silent Night	A post advertising the sale of a new banking Trojan for Windows called Silent Night [Russian: Тихая ночь]. The malware is an improved version of the Axe bot Trojan and has the following features: form grabber, keylogger, SOCKS5 backconnect, loader, web injects, and others. The malware runs on Windows XP–10 (x86/x64).
Web phishing	A user nicknamed zero0day made a post about selling Amazon, Apple, Outlook, and Microsoft Office 365 phishing pages targeted at customers in the US, Canada, and the UK. Communication with the threat actor revealed that their team can create any phishing pages upon request within three days. The price for a page starts at $50. The threat actor said they had two pages at the moment with full information gathered from services such as Netflix, PayPal, and Boursorama bank.

Arrests and sentences

Aleksey Burkov

A Russian hacker faces up to 80 years in prison. In late October 2019, Israeli Justice Minister Amir Ohana signed an order to extradite to the United States Aleksey Burkov, a 29-year-old citizen of Russia. Burkov was arrested in Ben Gurion Airport as early as 2015 at the request of the United States. Prosecutors say Burkov ran a website called Cardplanet that sold card data for anywhere from $2.50–$60 apiece.

Sergiy Usatyuk

The US Department of Justice announced that Sergiy Usatyuk, a 21-year-old citizen of the United States, had been sentenced to 13 months in prison. In the spring of 2019, Usatyuk pleaded guilty to owning, administering, and supporting illegal booster services that launched DDoS attacks. From August 2015 through November 2017, Usatyuk and his unnamed co-conspirator from Canada managed various resources such as ExoStress.in, QuezStresser.com, Betabooter.com, Databooter.com, Instabooter.com, and polystress.com. Prosecutors say ExoStresser alone, which appeared in September 2017, launched 1,367,610 DDoS attacks and caused targeted victim computer systems to suffer 109,186 hours of network downtime. By renting out capacities for DDoS attacks and advertising other boosters Usatyuk and his co-conspirator made a total of about $550,000.

Eric Meiggs

The US Department of Justice announced that Eric Meiggs, 21, and Declan Harrington, 20, had been arrested. Meiggs and Harrington used techniques called “SIM swapping.” The idea of such attacks is that a threat actor contacts their victim’s phone carrier and applies social engineering techniques. For instance, the threat actor poses as the real owner of the phone number and claims they lost or broke their SIM card, convincing the phone carrier to reassign the phone number to a new SIM card. The threat actor then steals accounts linked to the phone number, essentially stealing the victim’s entire identity. Prosecutors say Meigg and Harrington mostly targeted executives of cryptocurrency companies and users who had significant amounts of cryptocurrency in their Coinbase or Block.io wallets. In addition, the fraudsters were interested in the owners of high-value accounts on Instagram and Tumblr.

Forecasts and warnings

- The leading and most frightening trend of 2019 was the use of cyberweapons in military operations. Conflicts between states have taken on new forms, and cyber activity plays a leading role in this destructive dialogue. Attacks on critical infrastructure and targeted destabilization of the Internet in certain countries are breaking new ground on cyberattacks. A peaceful existence is no longer possible while being out of touch with cybersecurity. The latter cannot be ignored by any state, corporation, or individual.
- The first half of 2019 saw a ten-fold increase in the number of emails containing malware inside password-protected objects (documents or archives). In 2017, password-protected archives accounted for just 0.08% of the total number of malicious objects. In 2018, their number grew to 3.6%. The first half of 2019 saw an unusually sharp spike to 27.8% and this trend will continue.
- Nowadays, the most social and economic damage can be caused by depriving people and businesses of Internet access. That being said, countries that build centralized access control to the Internet are becoming more vulnerable and may become the first targets.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com